



Ejercicio de Simulación de Crisis

Table Top Exercise (TTX) · Ransomware · Spear Phishing · Blind Eagle
APT

Preparado para **Seguros Alfa** — Gerencia de Riesgos y Tecnología ·
Colombia 2026



Que es Spear Phishing ?

El Spear Phishing es una forma de ataque cibernético más precisa que el phishing masivo o común, ya que emplea inteligencia previa para hacerse pasar por identidades de confianza como directivos, proveedores o entes reguladores previamente identificados y estudiados, con el objetivo de engañar a empleados específicos de una organización. Este ataque no tiene como único objetivo infectar un ordenador, sino también comprometer procedimientos esenciales como la autorización de pagos, el acceso a bases de datos de asegurados, la modificación de documentación y obtención de información de más valor para realizar un mayor escalamiento de su ataque. Se caracteriza por una personalización extrema en los mensajes, como es usada por el grupo el grupo Blind Eagle, el cual presenta una actividad continua en Colombia. Diseñan mensajes que imitan perfectamente comunicaciones de la DIAN o la Superintendencia Financiera, utilizando un lenguaje legal y corporativo impecable que elude las sospechas habituales. No son envíos al azar; son ataques dirigidos a perfiles con privilegios elevados y acceso a procesos críticos, como analistas de tesorería, gerentes de riesgos o directores de cumplimiento. El objetivo final es vulnerar la cadena de mando y los activos más valiosos de la organización.

¿Por qué Seguros Alfa necesita este ejercicio?

El grupo **Blind Eagle (APT-C-36)** opera activamente en Colombia, suplantando entidades como la **DIAN** y la **Superintendencia Financiera** para comprometer perfiles con acceso privilegiado: gerentes de riesgo, directores de cumplimiento y analistas de tesorería.

Activos en riesgo

Bases de datos de asegurados, sistemas de siniestros y flujos de pago.

Vector silencioso

Un correo falso de la SFC puede comprometer credenciales sin alertas durante semanas.

Impacto financiero

Pérdidas promedio superiores a **USD 2.8M** por incidente en el sector financiero colombiano.





**En 2024, los ataques de
ransomware en
Latinoamérica aumentaron
un 70%, comparado con solo
un 8% en Norteamérica**

Fuente :

<https://www.brightdefense.com/resources/ransomware-statistics/>



Arquitectura del Ejercicio TTX

Diseñado bajo el estándar **NIST CSF 2.0** e integrado con la matriz **MITRE ATT&CK**, el ejercicio se desarrolla en tres fases progresivas que elevan gradualmente la presión sobre el equipo directivo.



Duración total: **4.5 horas** · Incluye briefing inicial (15 min) + debriefing ejecutivo (30 min).



Las Tres Fases en Detalle

Fase 1 · Detección & Contención

Infiltración silenciosa. El equipo identifica el vector Spear Phishing, contiene el movimiento lateral y decide si aislar sistemas críticos.

- ¿Cuándo se activa el Comité de Crisis?
- ¿Qué sistemas se aíslan y bajo qué criterio?

Fase 2 · Comunicación & Crisis

El ransomware cifra servidores de siniestros. Llegada una nota de rescate. La SFC solicita información. Dilemas éticos, legales y reputacionales en simultáneo.

- ¿Se paga el rescate? ¿Quién autoriza?
- ¿Cuándo y cómo se notifica a la SFC?

Fase 3 · Continuidad & Recuperación

Activación del BCP/DRP. El equipo prioriza restauración de servicios, gestiona proveedores afectados y proyecta el impacto financiero total.

- ¿En qué orden se restauran los sistemas?
- ¿Cómo se gestiona a los reaseguradores?

Perfiles Directivos del Ejercicio



Cada rol recibe un **brief personalizado** con dilemas adaptados a su función. El lenguaje se adapta al perfil de negocio, no al técnico.



CEO / CFO

Escalar la crisis, autorizar pago de rescate, gestionar impacto económico y reaseguradores.



Legal / Compliance

Notificación a la SFC, riesgo regulatorio, SARLAF y decisión legal sobre el rescate.



Comunicaciones

Gestión de medios, comunicación a clientes afectados y protección reputacional.



Riesgos / CISO

Activación BCP/DRP, aislamiento de sistemas, coordinación técnica y reporte al Comité de Crisis.



Lo que Obtiene Seguros Alfa



1

Validar BCP/DRP

Verificar la efectividad real del plan de continuidad y recuperación ante desastres.

2

Brechas directivas

Identificar fallas en la toma de decisiones bajo presión del equipo directivo.

3

Cumplimiento SFC

Verificar protocolos de notificación a la SFC e Instrucción SARLAFT.

4

Madurez NIST CSF 2.0

Generar métricas de madurez y construir memoria muscular para crisis reales.



Entregables Incluidos



Informe Ejecutivo

15-20 páginas con hallazgos, brechas y recomendaciones. Listo para Junta Directiva.



Mapa de Calor

Brechas mapeadas contra los 5 dominios del NIST CSF: Identificar, Proteger, Detectar, Responder, Recuperar.



Plan de Acción (PAC)

15-20 acciones concretas con responsables, plazos y priorización por riesgo regulatorio.



TTX Playbook

Guion maestro reutilizable con injects, roles, tiempos y métricas de evaluación.



Dashboard de Madurez

Scorecard por rol: tiempo de respuesta, calidad de decisión, coordinación y comunicación.



Inversión & ROI

Valor Total del Servicio

\$17.000.000 COP

IVA no incluido

El costo promedio de un incidente de ransomware en el sector financiero colombiano supera los **USD 280.000** en recuperación, multas y pérdida de clientes.

✅ Este ejercicio representa menos del 0.5% de ese costo.

¿Qué incluye?

- Diseño y personalización del escenario TTX
- Facilitación del ejercicio (4.5 horas)
- Briefings individuales por rol
- Informe ejecutivo + Mapa de calor + PAC
- TTX Playbook reutilizable
- Dashboard de métricas de madurez
- 1 sesión de seguimiento a los 30 días



Reducción del tiempo de respuesta a incidentes



Cumplimiento regulatorio SFC demostrable



Reducción de primas de ciber-seguro



¿Listos para Comenzar?

Contáctenos para coordinar la sesión de kick-off y personalización del escenario para Seguros Alfa.

Contexto 100% colombiano

Escenarios con amenazas reales:
Blind Eagle, DIAN falsa, SFC falsa.

Frameworks aplicados

NIST CSF 2.0 · MITRE ATT&CK · ISO 27001 · CIS Controls v8 · SARLAFT / SFC

+80 TTX facilitados

Experiencia en sectores regulados. Lenguaje adaptado a Junta Directiva y equipo técnico.

 servicioclientereset@gmail.com ·  +57 305 7896246 ·

Confidencial — Elaborado exclusivamente para Seguros Alfa · 2026